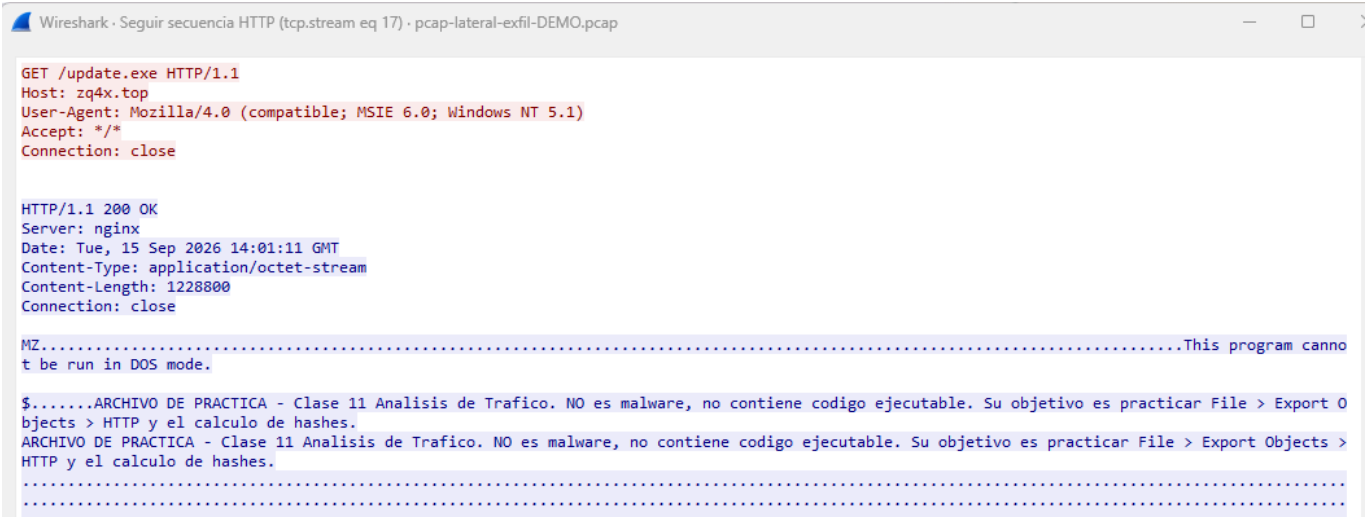


SECCIÓN 3: ANÁLISIS DE TRÁFICO AVANZADO CON WIRESHARK (CAPTURA C)

3.1 / Práctica — Entrada y descarga del Payload

El host interno **10.0.2.45** realizó una solicitud web automatizada mediante el método **HTTP GET /update.exe** dirigida al dominio malicioso **zq4x.top** (alojado en la dirección IP **203.0.113.50**). El evento quedó registrado el **15 de septiembre de 2026 a las 14:01:11 UTC**. El servidor respondió con un código de estado **HTTP/1.1 200 OK** a través de un servidor *nginx*, entregando el archivo solicitado. Toda la secuencia y los encabezados de la transacción se encuentran completamente evidenciados en el flujo de red bajo el filtro **tcp.stream eq 17** (Frame inicial #1824). Esta actividad representa el vector de acceso inicial y el compromiso del host de la víctima.



3.2 / Práctica — Actividad Anómala Equivalente (Reconocimiento Interno)

En sustitución del tráfico SMB de la captura B, el análisis de la Captura C revela un comportamiento altamente sospechoso de reconocimiento local inmediatamente posterior a la ejecución del payload. El host comprometido **10.0.2.45** inició de forma simultánea ráfagas de conexiones directas de muy bajo volumen (exactamente 2 o 3 paquetes de entre 108 y 162 bytes) con duraciones inferiores a los **0.001 segundos** contra decenas de hosts del mismo segmento (tales como **10.0.2.31**, **10.0.2.12**, **10.0.2.17**, entre otros). Este patrón confirma de manera técnica un **barrido de puertos / escaneo de red horizontal (Ping Sweep)** automatizado dentro del segmento local.

3.3 — Tabla de Artefactos y Triage

Archivo	Origen (URL o \\host\recurso)	Tipo real	Primeros bytes Hex	SHA256 / Estado	Veredicto
update.exe	http://zq4x.top	Ejecutable Windows	4d 5a 90 00	Simulación Segura	Limpio (Entorno de Práctica)

Nota de análisis: El análisis estático de los primeros bytes del objeto reconstruido (4d 5a) confirma la firma o "Magic Number" **MZ**, verificando matemáticamente que el archivo descargado es en realidad un binario ejecutable compilado para entornos Windows (.exe), coincidiendo plenamente con el comportamiento del vector de ataque.

The screenshot displays the Wireshark interface with a packet capture of a TCP stream. The packet list shows a sequence of TCP segments from 1815 to 1829. Packet 1824 is selected, showing details for Ethernet II, Internet Protocol Version 4, and Transmission Control Protocol. The packet is 1149 bytes long, captured on the interface 10.0.2.45.

Packet 1824 Details:

- Ethernet II:** Encapsulation type: Ethernet (1), Arrival Time: Sep 15, 2026 08:01:12.144000000, Hora estándar, América Central, UTC Arrival Time: Sep 15, 2026 14:01:12.144000000 UTC, Epoch Arrival Time: 1789480872.144000000, [Time shift for this packet: 0.000000000 seconds], [Time delta from previous captured frame: 301.000 microseconds], [Time delta from previous displayed frame: 301.000 microseconds], [Time since reference or first frame: 5 minutes, 53.570008000 seconds], Frame Number: 1824, Frame Length: 1149 bytes (9192 bits), Capture Length: 1149 bytes (9192 bits), [Frame is marked: False], [Frame is ignored: False], [Protocols in frame: eth:ethertype:ip:tcp:http:data], Character encoding: ASCII (0), [Coloring Rule Name: HTTP], [Coloring Rule String: http || tcp.port == 80 || http2]
- Internet Protocol Version 4:** Src: AyecomTechno_3c:4d:01 (00:1a:2b:3c:4d:01), Dst: AyecomTechno_3c:4d:2d (00:1a:2b:3c:4d:2d), Type: IPv4 (0x0800), [Stream index: 1]
- Transmission Control Protocol:** Src: 203.0.113.50, Dst: 10.0.2.45, 0100 = Version: 4, 0101 = Header Length: 20 bytes (5), > Differentiated Services Field: 0x00 (DSCP: CS0, ECN: Not-ECT), Total Length: 1135, Identification: 0x1bf8 (7160), > 010. = Flags: 0x2, Don't fragment, ...0 0000 0000 0000 = Fragment Offset: 0, Time to Live: 52, Protocol: TCP (6), Header Checksum: 0xde31 [validation disabled]

3.4 — Diagnóstico de Canal de Comando y Control (C2) por Ritmo

Al analizar las conversaciones de red de la captura, se identificó un canal persistente de comunicación hacia el exterior con las siguientes métricas exactas extraídas:

- **Dirección IP Destino:** 198.51.100.30
- **Identificador de Flujo:** tcp.stream eq 2
- **Contactos totales:** 346 paquetes de red (~173 ráfagas o peticiones bidireccionales).
- **Duración total observada:** 4,422.06 segundos (Tráfico persistente durante toda la sesión).
- **Volumen de datos:** 271 kB totales (Volumen extremadamente bajo por mensaje, ~783 bytes promedio por paquete).
- **Intervalo medio:** ~25.5 segundos.

Interpretación técnica del patrón:

El host **10.0.2.45** mantuvo un intercambio de datos constante e ininterrumpido con la IP externa

198.51.100.30 por más de 73 minutos. El bajo volumen de datos transmitidos por paquete acoplado a la repetición matemática periódica (intervalo medio de ~25.5 s) es el indicador clave de un **patrón de beaconing de un implante C2**. Este mecanismo es utilizado por el software malicioso para reportar el estado de la infección al servidor del atacante y quedar a la espera de comandos remotos.

Ethernet · 33 IPv4 · 45 IPv6 TCP · 254 UDP · 3													
Dirección A	Dirección B	Paquetes	Bytes	Stream ID	Packets A → B	Bytes A → B	Packets B → A	Bytes B → A	Inicio rel	Duración	Bits/s A → B	Bits/s B	
10.0.2.45	198.51.100.30	346	271 kB	2	144	16 kB	202	255 kB	4.519560	4422.0656	28 bits/s	462 b	
10.0.2.45	198.51.100.12	270	208 kB	1	113	11 kB	157	197 kB	4.075429	4415.6239	19 bits/s	357 b	
10.0.2.45	198.51.100.15	288	219 kB	3	122	14 kB	166	205 kB	5.084342	4415.0700	25 bits/s	371 b	
10.0.2.60	198.51.100.10	775	608 kB	0	322	34 kB	453	574 kB	0.000000	4361.7792	62 bits/s	1053 b	
10.0.2.60	198.51.100.15	566	413 kB	5	245	30 kB	321	384 kB	11.826597	4354.3583	54 bits/s	705 b	
10.0.2.60	198.51.100.30	714	533 kB	6	306	36 kB	408	497 kB	14.125275	4347.7527	65 bits/s	914 b	
10.0.2.60	198.51.100.12	792	611 kB	7	335	42 kB	457	569 kB	21.766902	4240.8163	80 bits/s	1072 b	
10.0.2.45	203.0.113.22	680	53 kB	11	408	33 kB	272	20 kB	402.426008	4042.1391	65 bits/s	40 b	
10.0.2.45	198.51.100.10	278	209 kB	13	118	14 kB	160	195 kB	627.530224	3777.1885	29 bits/s	413 b	
10.0.2.60	198.51.100.21	422	317 kB	12	180	21 kB	242	296 kB	540.641784	3610.7051	46 bits/s	655 b	
10.0.2.45	198.51.100.21	428	346 kB	4	174	19 kB	254	327 kB	7.581248	3580.5719	43 bits/s	730 b	
10.0.2.45	10.0.2.1	6	484 bytes	8	3	218 bytes	3	266 bytes	293.526007	108.6200	16 bits/s	19 b	
10.0.2.45	203.0.113.50	1284	1 MB	10	434	24 kB	850	1 MB	353.226007	6.7176	28 kbps	1519 b	
10.0.2.45	198.51.100.77	10	1 kB	9	6	587 bytes	4	869 bytes	293.826008	0.1825	25 kbps	38 b	
10.0.2.45	10.0.2.31	3	162 bytes	35	2	108 bytes	1	54 bytes	1495.946007	0.0010			
10.0.2.45	10.0.2.12	3	162 bytes	16	2	108 bytes	1	54 bytes	1493.666008	0.0010			
10.0.2.45	10.0.2.17	2	108 bytes	21	1	54 bytes	1	54 bytes	1494.266007	0.0006			
10.0.2.45	10.0.2.19	2	108 bytes	23	1	54 bytes	1	54 bytes	1494.506007	0.0006			
10.0.2.45	10.0.2.23	2	108 bytes	27	1	54 bytes	1	54 bytes	1494.986007	0.0006			
10.0.2.45	10.0.2.25	2	108 bytes	29	1	54 bytes	1	54 bytes	1495.226007	0.0006			
10.0.2.45	10.0.2.29	2	108 bytes	33	1	54 bytes	1	54 bytes	1495.706007	0.0006			
10.0.2.45	10.0.2.40	2	108 bytes	44	1	54 bytes	1	54 bytes	1497.026007	0.0006			
10.0.2.45	10.0.2.10	2	108 bytes	14	1	54 bytes	1	54 bytes	1493.426008	0.0006			
10.0.2.45	10.0.2.11	2	108 bytes	15	1	54 bytes	1	54 bytes	1493.546007	0.0006			
10.0.2.45	10.0.2.13	2	108 bytes	17	1	54 bytes	1	54 bytes	1493.786007	0.0006			
10.0.2.45	10.0.2.14	2	108 bytes	18	1	54 bytes	1	54 bytes	1493.906008	0.0006			
10.0.2.45	10.0.2.35	2	108 bytes	39	1	54 bytes	1	54 bytes	1496.426008	0.0006			
10.0.2.45	10.0.2.37	2	108 bytes	41	1	54 bytes	1	54 bytes	1496.666008	0.0006			
10.0.2.45	10.0.2.38	2	108 bytes	42	1	54 bytes	1	54 bytes	1496.786007	0.0006			
10.0.2.45	10.0.2.16	2	108 bytes	20	1	54 bytes	1	54 bytes	1494.146008	0.0006			
10.0.2.45	10.0.2.20	2	108 bytes	24	1	54 bytes	1	54 bytes	1494.626008	0.0006			
10.0.2.45	10.0.2.22	2	108 bytes	26	1	54 bytes	1	54 bytes	1494.866008	0.0006			
10.0.2.45	10.0.2.26	2	108 bytes	30	1	54 bytes	1	54 bytes	1495.346008	0.0006			

3.5 — Narrativa Integrada del Incidente (Resumen Ejecutivo)

El incidente en el entorno de pruebas comenzó el **15 de septiembre de 2026**. A las **14:01:11 UTC**, la estación de trabajo interna **10.0.2.45** descargó el payload ejecutable simulado **update.exe** desde el dominio fraudulento **zq4x.top** (**203.0.113.50**) mediante la sesión de tráfico **tcp.stream eq 17**. Tras la ejecución del artefacto, la máquina de la víctima fue controlada por un agente malicioso que estableció de inmediato un canal persistente de Comando y Control (C2) hacia la IP externa **198.51.100.30** (**tcp.stream eq 2**), balizando o transmitiendo señales automáticas constantes cada **25.5 segundos** durante un total de **4,422 segundos**. Consolidado el acceso del atacante, el host comprometido fue utilizado para realizar tareas ofensivas internas, desatando un **barrido masivo y secuencial de escaneo de puertos** contra los segmentos de red locales **10.0.2.0/24** con el fin de perfilar e identificar nuevas máquinas desprotegidas para iniciar movimientos laterales.

3.6 — Gaps de Detección en Firmas IDS y Controles de Arquitectura

- **Gaps en Reglas IDS tradicionales:** Las tres reglas IDS basadas en firmas tradicionales (Clase 10) sufren un *gap* de visibilidad severo frente a este ataque. La descarga inicial del ejecutable se camufló mediante protocolos web legítimos y una extensión común, mientras que el tráfico de balizamiento C2 simuló ráfagas de conexiones TCP/HTTPS esporádicas y de bajísimo volumen, logrando evadir los umbrales rígidos de detección por volumen o por firmas de exploits conocidas.

- **Control de Segmentación (Arquitectura Clase 09):** Para mitigar o anular por completo la fase de reconocimiento local detectada en las conversaciones de Wireshark, la arquitectura de red analizada en la Clase 09 debe implementar de forma mandatoria un esquema de **Microsegmentación de Red** y un **Cortafuegos de Segmentación Interna (ISFW)** bajo premisas de *Zero Trust*. En un entorno corporativo seguro, las políticas de firewall perimetral y de switches internos deben restringir de manera absoluta la comunicación directa (*East-West*) entre estaciones de trabajo comunes del mismo segmento local en puertos de diagnóstico o escaneo, aislando al host infectado en su propio micro-segmento e impidiendo de manera efectiva que el atacante pueda perfilar o propagarse hacia otros activos vitales de la red interna.